OctoMatrix: un Mixture-of-Experts por procedencia de datos para la detección de ataques OWASP en tráfico HTTP

Santiago Potes Giraldo
Semillero BlackByte · Universidad Tecnológica de Pereira
Docente: Biviana Yulieth Aguirre Arias

Resumen — Se presenta OctoMatrix, un detector de anomalías OWASP sobre peticiones HTTP. El prototipo inicial se entrenaba con 72 ejemplos sintéticos escritos a mano y reportaba 83% de exactitud sobre 15 muestras de prueba, una medición sin validez estadística. Este trabajo reconstruye el sistema sobre ~75.500 peticiones reales (CSIC 2010, ECML/PKDD 2007 y los tests de regresión del OWASP CRS) y lo evalúa con métricas propias de un WAF. La contribución central es una arquitectura Mixture-of-Experts (MoE) *por procedencia de datos*: expertos independientes para datos reales, para payloads generados y para flujos de red, combinados por OR a nivel de alerta, lo que evita el envenenamiento de datos que produce mezclar datos generados con reales en un solo modelo. El experto real alcanza recall 89,6% a 1% de FPR (ROC-AUC 0,989), pero ROC-AUC 0,53 al evaluar entre fuentes distintas, evidenciando que la limitación no es la cantidad de datos sino la diversidad de tráfico benigno.

Palabras clave — seguridad web, OWASP, WAF, random forest, mixture-of-experts, data poisoning, detección de anomalías.

I. INTRODUCCIÓN

Los firewalls de aplicación web (WAF) combinan reglas determinísticas con heurísticas de aprendizaje automático. Un detector basado en ML es útil sólo si se evalúa honestamente: un modelo entrenado y probado sobre un puñado de ejemplos sintéticos puede reportar métricas altas que no se sostienen ante tráfico real. Este trabajo parte de un prototipo con ese defecto y lo reconstruye con datos reales, particiones sin fugas y métricas orientadas a operación.

II. TRABAJO RELACIONADO Y DATOS

Se emplean cuatro fuentes públicas. CSIC 2010 provee tráfico HTTP real de una tienda web, etiquetado como normal o anómalo. ECML/PKDD 2007 aporta tráfico sintético con el tipo de ataque anotado (SQLi, XSS, LDAP, XPath, SSI, command injection, path traversal). El OWASP Core Rule Set incluye tests de regresión que son, por construcción, cargas de ataque etiquetadas por familia. CSE-CIC-IDS2018 aporta flujos de red (CICFlowMeter) con ataques de volumen (DoS, fuerza bruta). Los datos crudos no se redistribuyen; se descargan bajo demanda y se fija su versión exacta mediante hash.

III. METODOLOGÍA

A. Representación y características. Cada petición se representa como texto (método, ruta, query, cuerpo y cabeceras con payload) sin decodificar. Un FeatureUnion combina TF-IDF de n-gramas de caracteres con un vector de características de seguridad: conteos de patrones (SQL, XSS, traversal, etc.), entropía de Shannon, longitud, proporción de caracteres no alfanuméricos y racha máxima de un carácter.

B. Clasificador y calibración. Un Random Forest se envuelve en CalibratedClassifierCV (isotónica) para obtener probabilidades calibradas; sobre ellas se elige un umbral en validación para una tasa de falsos positivos objetivo. Un post-filtro regex (allowlist) rebaja falsos positivos sin inventar detecciones. Todo el preprocesamiento vive en un único Pipeline, eliminando el desajuste de características entre entrenamiento e inferencia.

C. Particiones sin fugas. Las peticiones casi-duplicadas se agrupan por una forma canónica y el grupo completo va a un solo conjunto. Además de la partición dentro de fuente, se definen escenarios *entre fuentes* (entrenar con unas y probar con otra) para medir generalización. La augmentación (codificación URL, cambios de caja, comentarios SQL) se aplica sólo a entrenamiento.

D. Mixture-of-Experts por procedencia. Mezclar datos reales con datos generados en un mismo modelo arriesga envenenamiento (las plantillas del generador sesgan los patrones reales); entrenar sólo con datos generados produce sobreajuste. La solución es un experto por procedencia: real, generado y flujos, combinados por OR. Cada experto se entrena y calibra por separado con su propio umbral; el generado sólo puede sumar detecciones, nunca altera al real.

IV. CONFIGURACIÓN EXPERIMENTAL

Tras unificar y deduplicar, el corpus de texto tiene 75.458 peticiones (27,9k ataques, 47,6k normales). Se reportan ROC-AUC, PR-AUC y recall a FPR de 1% y 0,1%, por categoría OWASP y por fuente. El umbral se fija en validación. El experto de flujos usa partición temporal por día.

V. RESULTADOS

Escenario	ROC	rec@1%	rec@0,1%
in_source	0,989	89,6%	59,1%
csic_ecml→crs	0,53	—	—
adversarial (MoE)	—	~100%	—
flujos IDS2018	1,00	100%	100%

Tabla I. Métricas por escenario.

El experto real es fuerte dentro de las fuentes vistas pero no generaliza a una fuente nueva (ROC-AUC 0,53). El MoE eleva la cobertura sobre un set adversarial propio de 19 categorías OWASP a recall ~100% con FPR 0,53%, mientras el FPR extra sobre el test real es +0,00%: el experto generado suma cobertura sin degradar al real. El experto de flujos separa DoS y fuerza bruta de forma casi perfecta, lo que refleja la separabilidad conocida de CIC-IDS2018 más que un resultado trasladable a producción.

VI. DISCUSIÓN Y LIMITACIONES

El hallazgo principal es diagnóstico: el cuello de botella no es la cantidad de ataques sino la *diversidad del tráfico benigno*. Con un único sitio (CSIC) y tráfico sintético (ECML), el modelo aprende el 'normal' de esas fuentes y marca como ataque cualquier tráfico legítimo distinto. Cerrar esta brecha requiere benigno real y variado (p. ej. logs propios). IDOR y escalada de privilegios son poco detectables sólo por el payload. El set adversarial se usa exclusivamente para medir; entrenar con él inflaría el resultado por memorización.

VII. CONCLUSIÓN Y TRABAJO FUTURO

Se reconstruyó un prototipo no validado en un sistema medible y reproducible, y se propuso un MoE por procedencia que amplía la cobertura OWASP sin envenenamiento. El trabajo futuro: incorporar tráfico benigno de múltiples sitios, correlacionar el experto de texto con el de flujos a nivel de evento, y cerrar el lazo de post-entrenamiento con revisión humana.

REFERENCIAS

[1] Information Security Institute (CSIC), “HTTP DATASET CSIC 2010”.

[2] ECML/PKDD 2007 Discovery Challenge, “Analyzing Web Traffic”.

[3] OWASP, “Core Rule Set regression tests”, coreruleset.

[4] Canadian Institute for Cybersecurity, “CSE-CIC-IDS2018”, UNB.